The S in IoT stands for Security

An overview on the Devices, Protocols, Architectures, and Security Threats of the Internet-of-Things Ecosystem

SEPRJ - ISEP, 16/06/2023

João Pedro Dias

$ whoami

João Pedro Dias, PhD

Software Engineer @ KUEHNE+NAGEL

Invited Assistant Professor @ U.PORTO FEUP FACULDADE DE ENGENHARIA UNIVERSIDADE DO PORTO

https://jpdias.me

jpmdias@fe.up.pt

Index

1. The Internet-of-Things *thing*
2. Let's get *smaller*: IoT devices
3. *The devil is in the details:* looking for vulnerabilities and finding them
4. OWASP Top 10 for IoT
5. Closing remarks

The Internet-of-Things *thing*

The definition by the standards

“An infrastructure of interconnected objects, people, systems and information resources together with intelligent services to allow them to process information of the physical and the virtual world and react.”

ISO/IEC JTC 1 Internet of Things (IoT)

In concrete terms

A network of physical objects — *things* — that are **embedded with sensors, actuators, software**, and other technologies for the purpose of connecting and exchanging data with other devices and systems **over the Internet**.

From Wikipedia, the free encyclopedia




0.65 kW




ring
ring

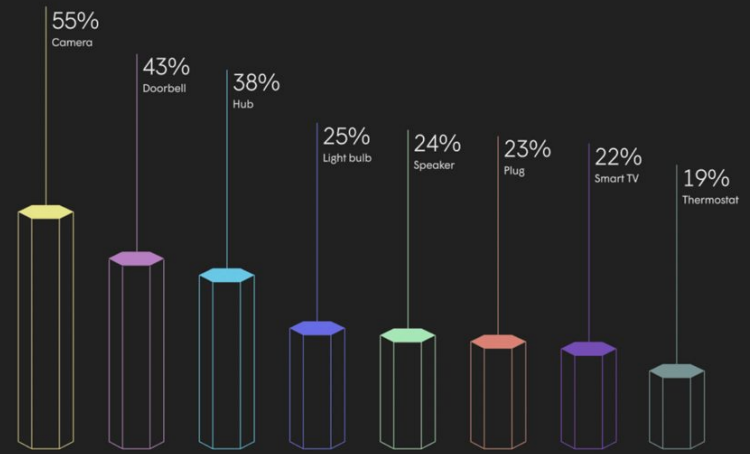

PHILIPS
hue


nest
70
nest
Google Home
Hands-free smart speaker



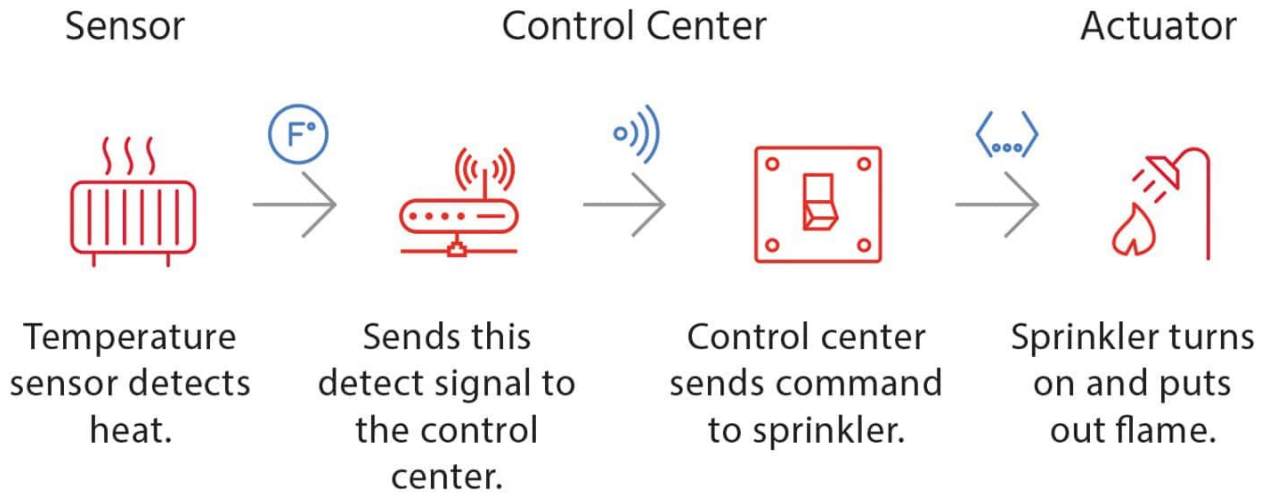
Some stats

“The average house in the U.S. now has 20.2 connected devices, according to a new report based on an analysis of 41 million homes and 1.8 thousand million connected devices. In Europe, the average is 17.4, while the average Japanese house contains only 10.3 smart devices.”



Smart Home: Apple Is The Fastest-Growing Connected Device Company, https://www.forbes.com/sites/johnkoetsier/2022/08/31/smart-home-apple-is-the-fastest-growing-connected-device-company/?sh=39cdf6d07dd4

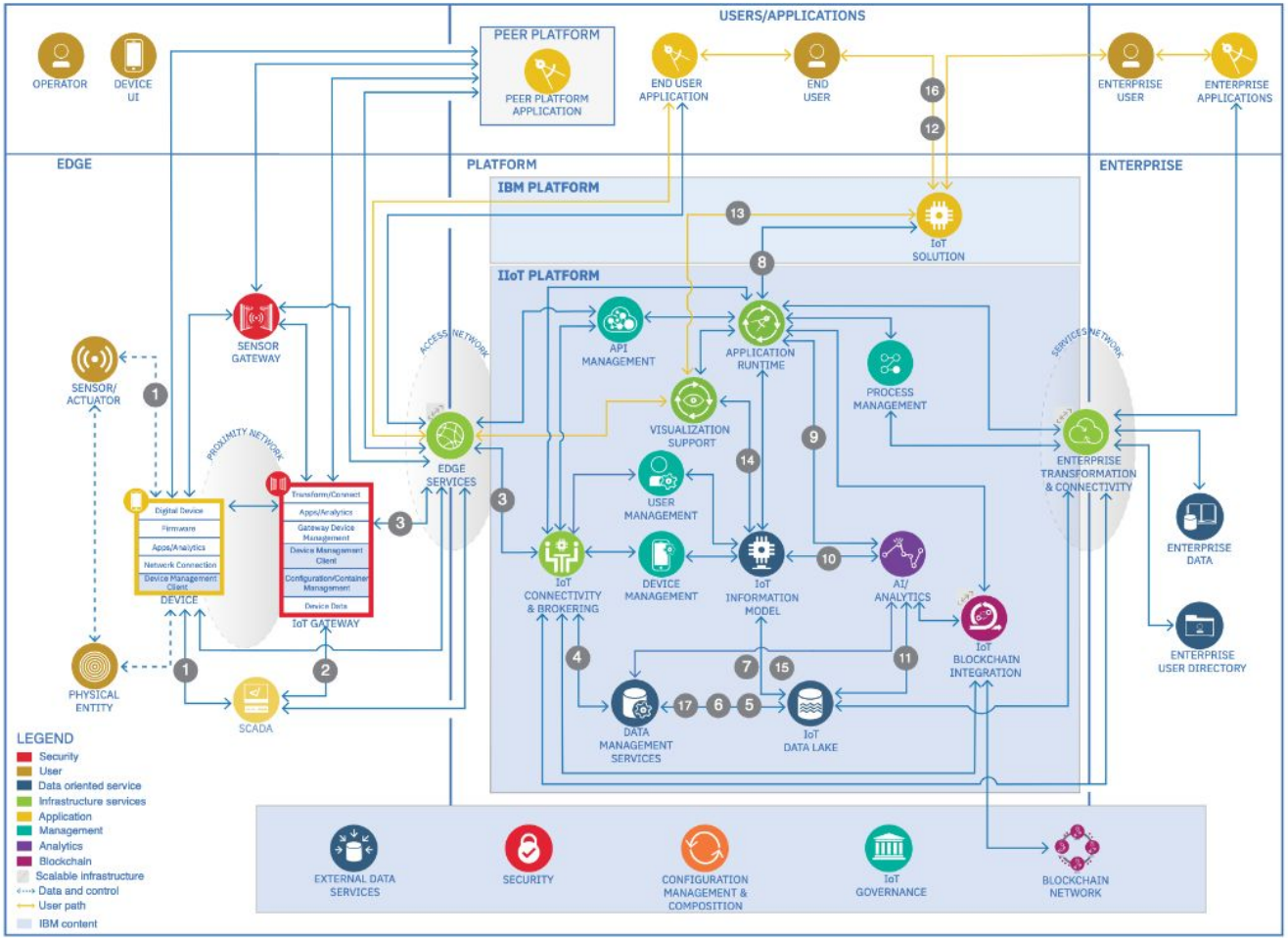
What happens in an IoT workflow



IoT: What Really Happens (architecture-wise)

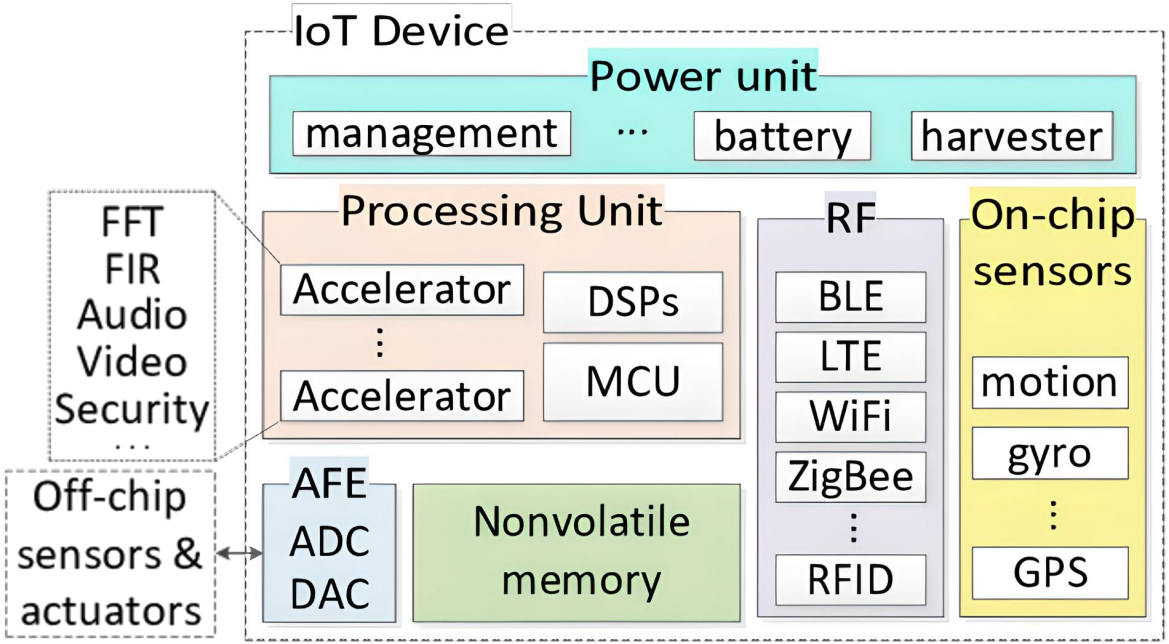
IBM reference architecture,

https://www.ibm.com/cloud/architecture/architectures/iotArchitecture/reference-architecture/



Let’s get *smaller*: IoT devices

General Architecture of an IoT device



James, A., Seth, A., Mukhopadhyay, S.C. (2022). Design Considerations for IoT Node. In: IoT System Design. Smart Sensors, Measurement and Instrumentation, vol 41. Springer, Cham. https://doi.org/10.1007/978-3-030-85863-6_3

Linux everywhere? *Not so fast*

Real-time Operating Systems

RIOT

freeRTOS

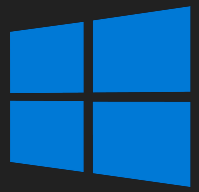
arm MBED OS

Zephyr™

Traditional Operating Systems



yocto PROJECT



Baremetal

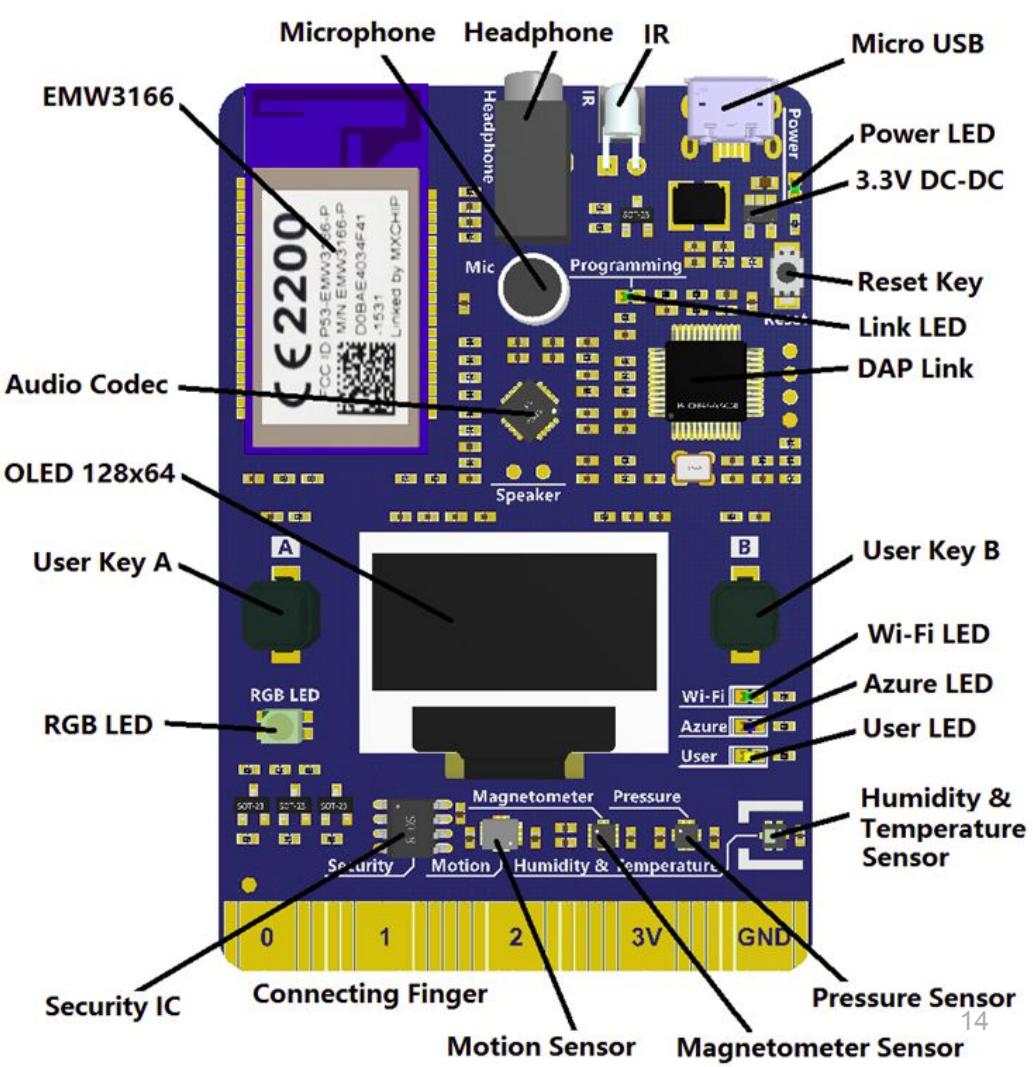
ARDUINO



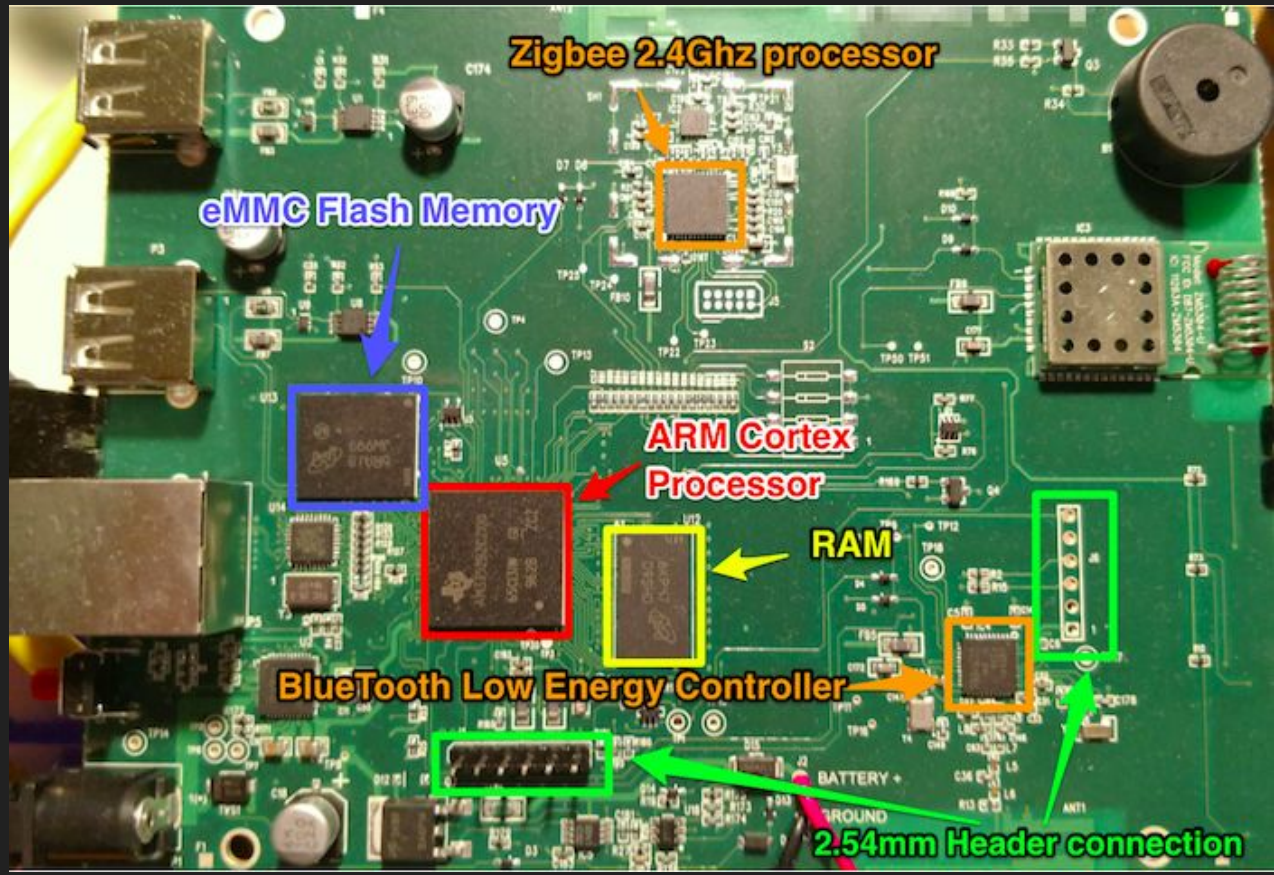


Example Device 1: Azure IoT DevKit

An all-in-one IoT kit built for the cloud, https://microsoft.github.io/azure-iot-developer-kit/



Example Device 2: (Unknown) ZigBee Gateway

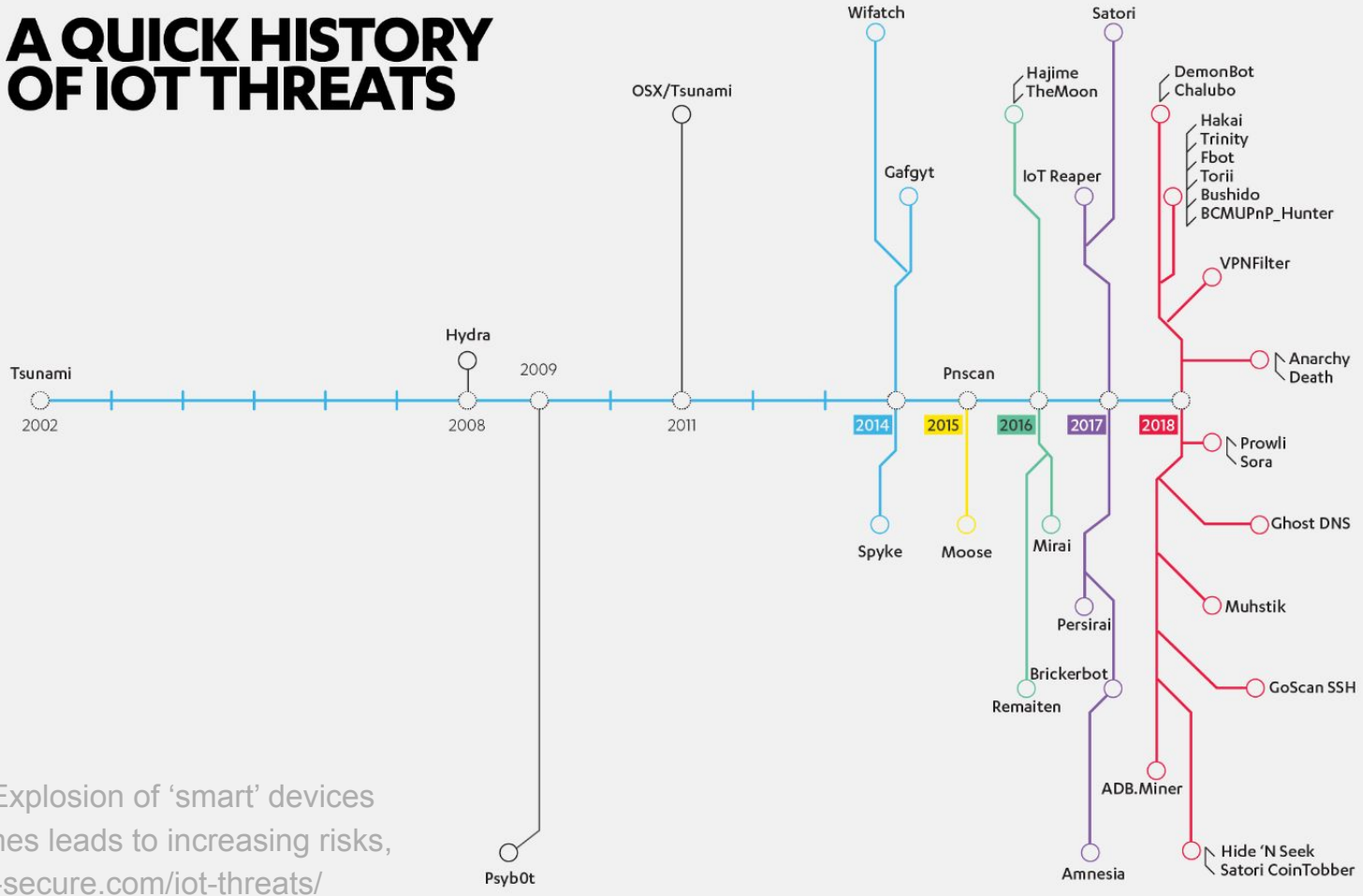


[IoT Security] Introduction to Embedded Hardware Hacking, https://www.rapid7.com/blog/post/2019/02/20/iot-security-introduction-to-embedded-hardware-hacking/

The devil is in the details:

looking for vulnerabilities and finding them

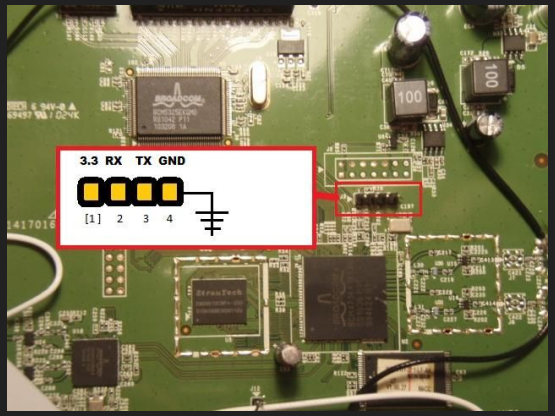
A QUICK HISTORY OF IOT THREATS



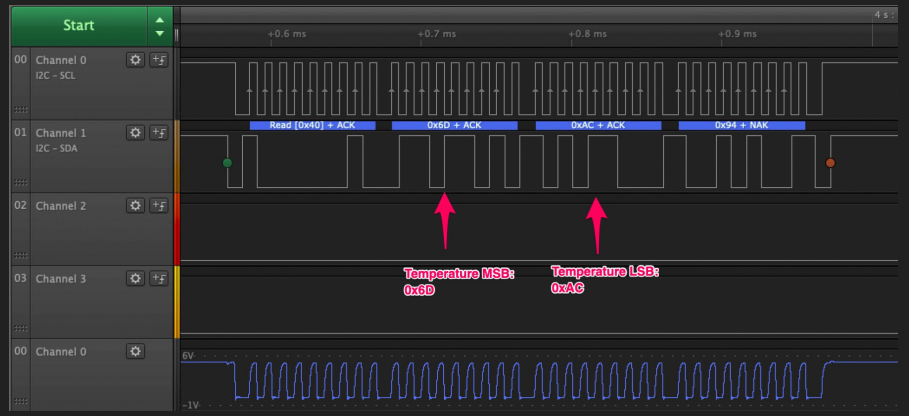
IoT threats: Explosion of 'smart' devices filling up homes leads to increasing risks, https://blog.f-secure.com/iot-threats/

If you have hardware access…

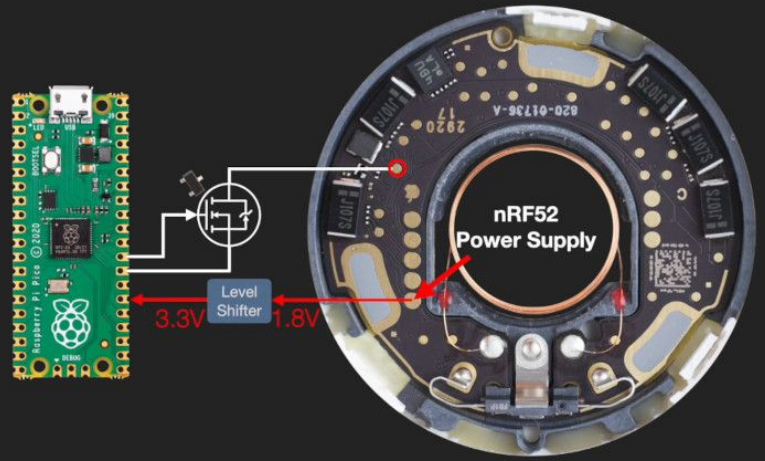
- Local Interfaces (JTAG, Serial, USB,...)
  - Dump flash memory, etc.
- Differential Power Analysis (DPA)
- Glitching (Voltage, Temp, Magnetics)
- Probing

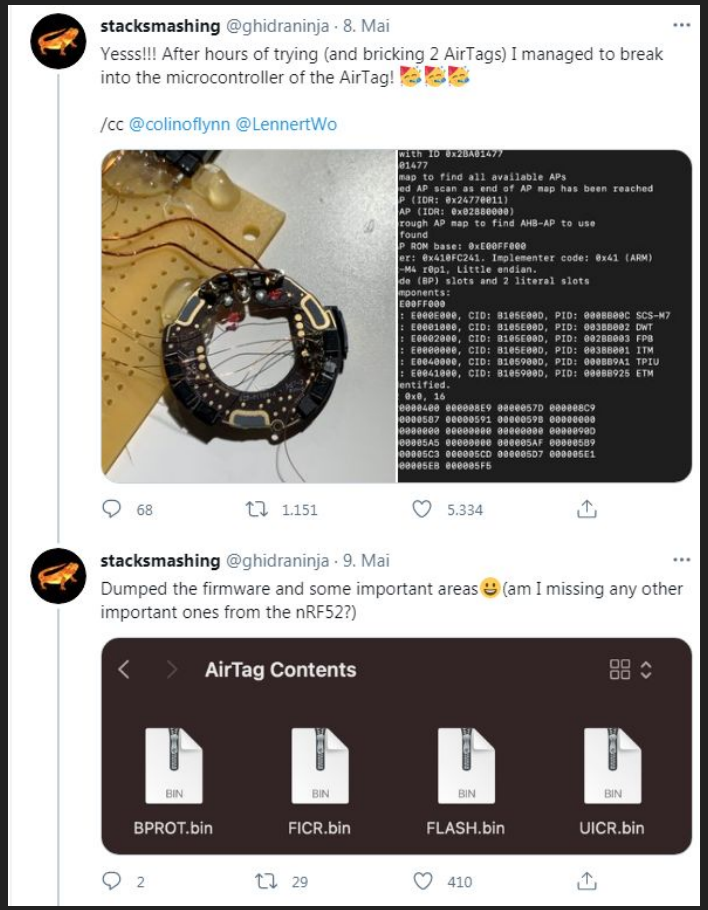






AirTag Glitch Attack example

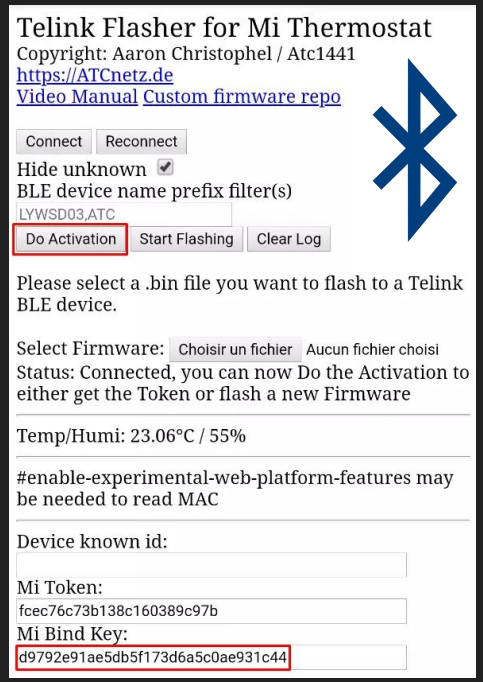




Xiaomi Mi Temperature/Humidity Sensor example





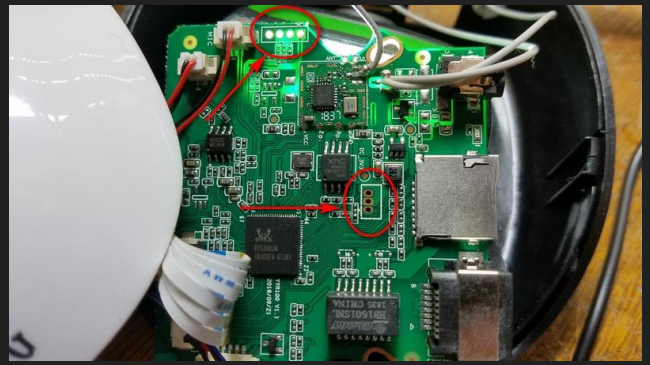






Random IP Camera example





```
Board: IPCAM RTS3903 CPU: 500M :rx5281 prid=0xdc02
force spi nor mode
DRAM:  64 MiB @ 1066 MHz
Skipping flash_init
Flash: 0 Bytes
flash status is 0, 0, 0
SF: Detected XM25QH64A with page size 256 Bytes, erase size 64 KiB,
Using default environment

In:    serial
Out:   serial
Err:   serial
Net:   Realtek PCIe GBE Family Controller mcfg = 0024
no hw config header
new_ethaddr = 4C:B0:08:39:04:10
r8168#0
no hw config header
Hit any key to stop autoboot:  1  0
flash status is 0, 0, 0
SF: Detected XM25QH64A with page size 256 Bytes, erase size 64 KiB,
SF: 1769472 bytes @ 0x50000 Read: OK
## Booting kernel from Legacy Image at 80100000 ...
get header OKimage_get_kernel check hcrc
image_get_kernel print contents
   Image Name:   linux_3.10
   Created:      2018-08-30   2:48:25 UTC
   Image Type:   MIPS Linux Kernel Image (uncompressed)
   Data Size:    1654849 Bytes = 1.6 MiB
   Load Address: 804bfc10
   Entry Point:  804bfc10
   Verifying Checksum ... OK
   Loading Kernel Image ... OK

Starting kernel ...

[    0.000000] Linux version 3.10.27 (xkwy@ubuntu-hw-1404) (gcc ver
PREEMPT Thu Aug 30 10:48:20 CST 2018
```

```
# ls
bin      etc      lib      mnt      res
dev      ipc      linuxrc  proc     rom
# echo $USER
root
#
```

```
PORT     STATE SERVICE VERSION
554/tcp  open  rtsp?
|_rtsp-methods: OPTIONS, DESCRIBE, SETUP, TEARDOWN, PLAY, PAUSE, GET_PARAMETER, SET_PARAMETER,USER_CMD_SET
5000/tcp open  upnp?
MAC Address: 30:4A:26:23:59:C3 (Unknown)
Device type: general purpose
Running: Linux 3.X
OS CPE: cpe:/o:linux:linux_kernel:3
OS details: Linux 3.2 - 3.10, Linux 3.2 - 3.16
Uptime guess: 176.904 days (since Fri Sep 21 09:22:49 2018)
Network Distance: 1 hop
TCP Sequence Prediction: Difficulty=260 (Good luck!)
IP ID Sequence Generation: All zeros
```

If you are near enough…

- 433MHz Replay Attacks
  - Or how to open the neighbor garage door
- Zigbee Link key Vulnerability
  - ZigBee standard permits the re-use of link keys for rejoining the network
- Bluetooth LE Link Layer Memory Corruption
  - Crash the device and the device could be remotely restarted
- Bluetooth LE Zero LTK Installation
  - Arbitrary read or write access to the device's functions
- WiFi vulnerabilities
  - Key Reinstallation Attacks, Fragmentation and aggregation attacks, Deauth, …
- Esoteric attacks
  - Laser-Based Audio Injection on Voice-Controllable Systems

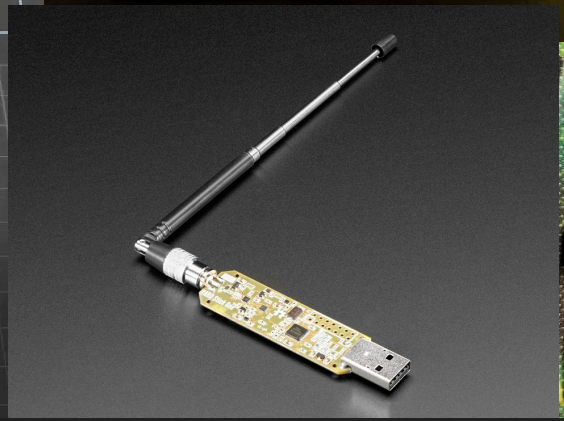
Some useful toys











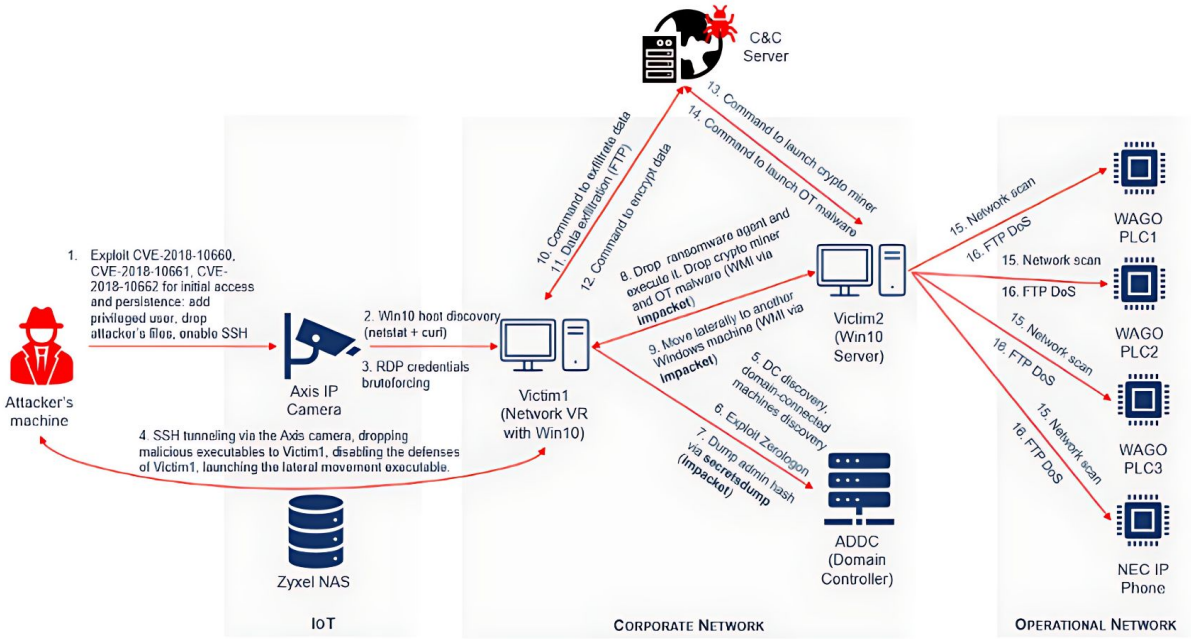


More tools:
https://github.com/yadox666/The-Hackers-Hardware-Toolkit/blob/master/TheHackersHardwareToolkit.pdf

If it is Internet connected…

- Traditional web-related vulnerabilities
  - OWASP Top 10, https://owasp.org/Top10/
  - OWASP API Security Top 10, https://owasp.org/API-Security/editions/2023/en/0x00-header/
- Vulnerabilities from IoT-focused protocols:
  - CoAP
  - MQTT (and variants)
  - XMPP
  - DDS

Anatomy of an Attack



R4IoT: When Ransomware Meets IoT and OT, https://www.forescout.com/resources/r4iot-next-generation-ransomware-report/

OWASP IoT Top 10 (2018)

OWASP Internet of Things (IoT) Project, https://wiki.owasp.org/index.php/OWASP_Internet_of_Things_Project#tab=Main

1 Weak, Guessable, or Hardcoded Passwords

Use of easily bruteforced, publicly available, or unchangeable credentials, including backdoors in firmware or client software that grants unauthorized access to deployed systems.



2 Insecure Network Services

Unneeded or insecure network services running on the device itself, especially those exposed to the internet, that compromise the confidentiality, integrity/authenticity, or availability of information or allow unauthorized remote control...



3 Insecure Ecosystem Interfaces

Insecure web, backend API, cloud, or mobile interfaces in the ecosystem outside of the device that allows compromise of the device or its related components. Common issues include a lack of authentication/authorization, lacking or weak encryption, and a lack of input and output filtering.



4 Lack of Secure Update Mechanism

Lack of ability to securely update the device. This includes lack of firmware validation on device, lack of secure delivery (un-encrypted in transit), lack of anti-rollback mechanisms, and lack of notifications of security changes due to updates.



5 Use of Insecure or Outdated Components

Use of deprecated or insecure software components/libraries that could allow the device to be compromised. This includes insecure customization of operating system platforms, and the use of third-party software or hardware components from a compromised supply chain.



6 Insufficient Privacy Protection

User's personal information stored on the device or in the ecosystem that is used insecurely, improperly, or without permission.



7 Insecure Data Transfer and Storage

Lack of encryption or access control of sensitive data anywhere within the ecosystem, including at rest, in transit, or during processing.



8 Lack of Device Management

Lack of security support on devices deployed in production, including asset management, update management, secure decommissioning, systems monitoring, and response capabilities.



9 Insecure Default Settings

Devices or systems shipped with insecure default settings or lack the ability to make the system more secure by restricting operators from modifying configurations.



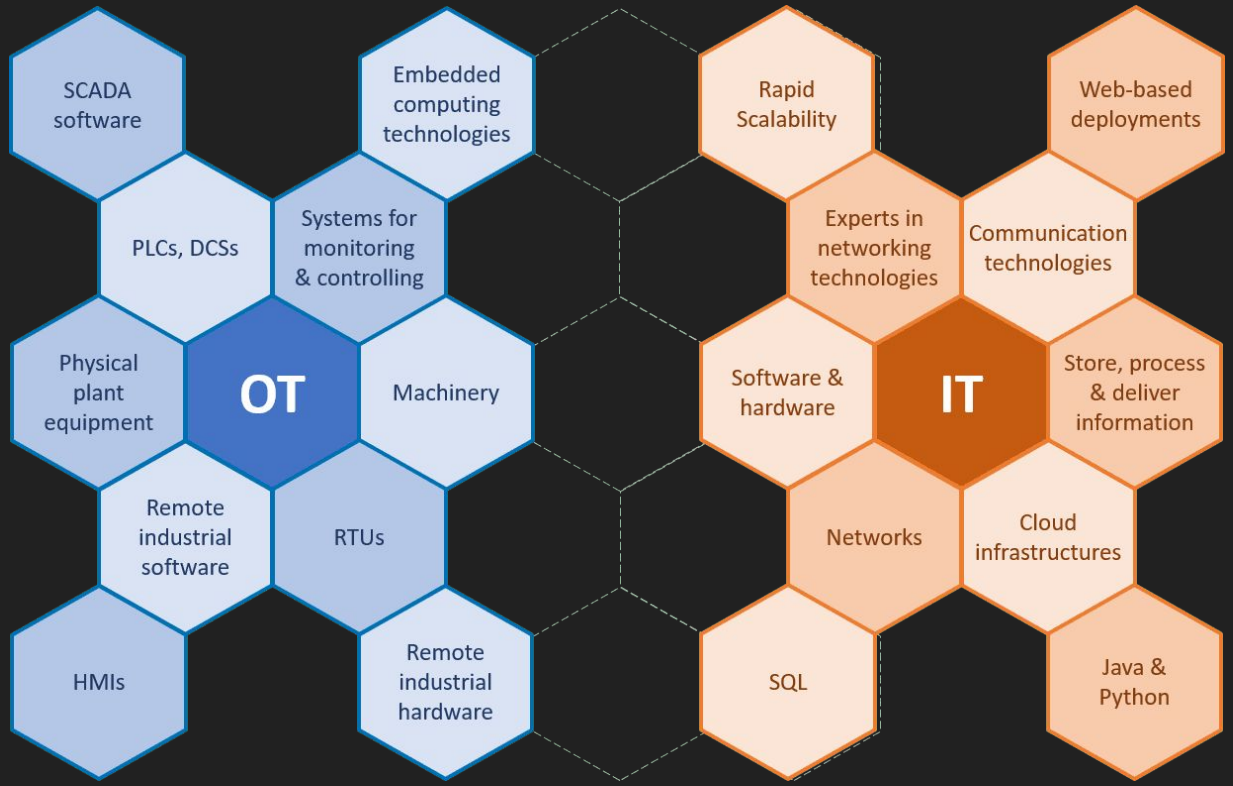
10 Lack of Physical Hardening

Lack of physical hardening measures, allowing potential attackers to gain sensitive information that can help in a future remote attack or take local control of the device.



Closing remarks

Moving from IT to OT (IoT)



Trust but verify (!)

- “Google Calls Hidden Microphone in Its Nest Home Security Devices an 'Error'”
- “Amazon Buys Roomba Company, Will Now Map Inside of Your House”
- “(...) an airport in Rome discovered that one of their security systems, which consisted of over 100 **Hikvision CCTV cameras**, was sending huge packets of data to a chain of IP addresses that ended in China.”
- “Smart lightbulbs could be exporting your personal data to China”
- “Why (Amazon) Ring Doorbells Perfectly Exemplify the IoT Security Crisis: A new wave of reports about the home surveillance cameras getting hijacked by creeps is painfully familiar.”

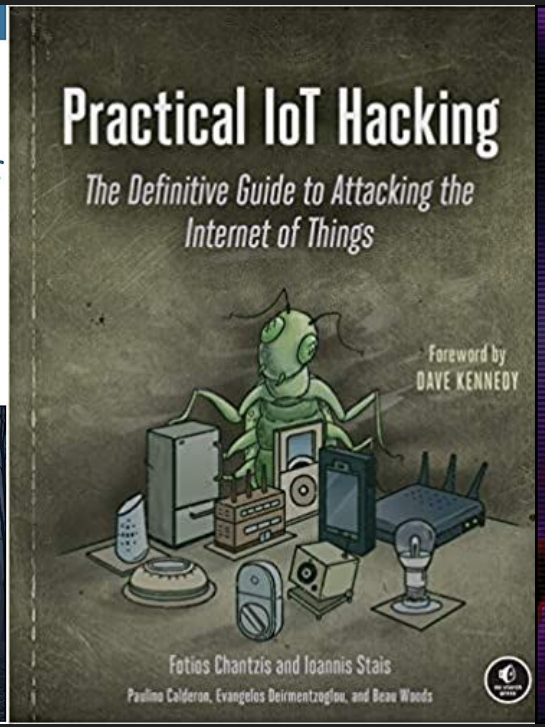
Some advice from the Internet (Twitter)

- Customers must be notified if security updates are no longer occurring for a given device. (@daeken)
- Proper channels for reporting vulnerabilities. (@daeken)
- Minimize attack surface. (@daeken)
- Keep third-party software up to date. (@daeken)

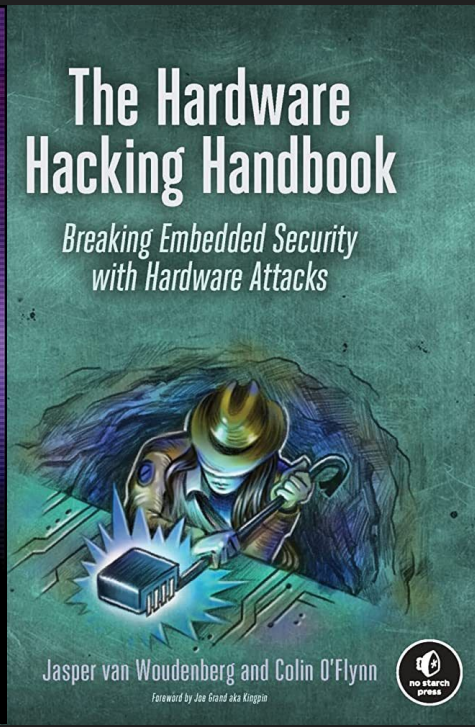
- No cloud service should ever have access to your sensitive home devices or even know what you're doing. (@creationix)
- Devices should always work when you’re at home, even without Internet connectivity. (@creationix)
- Communicating with devices while at home should have far less latency than is typical. (@creationix)

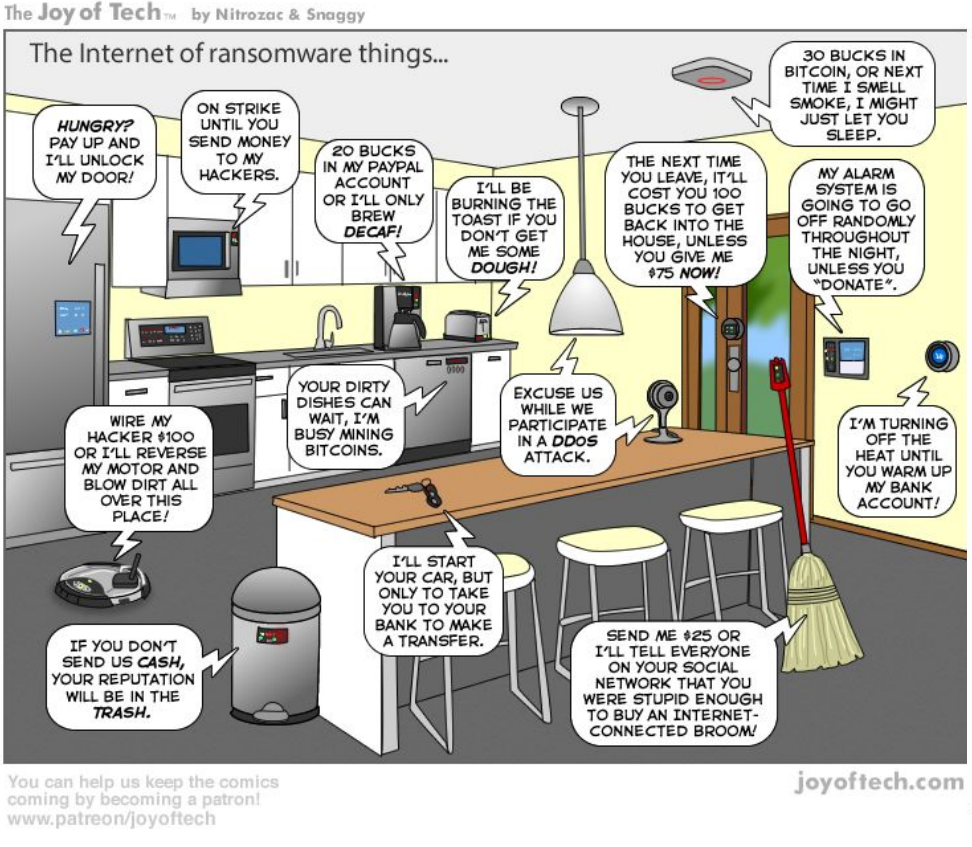
Some reading suggestions



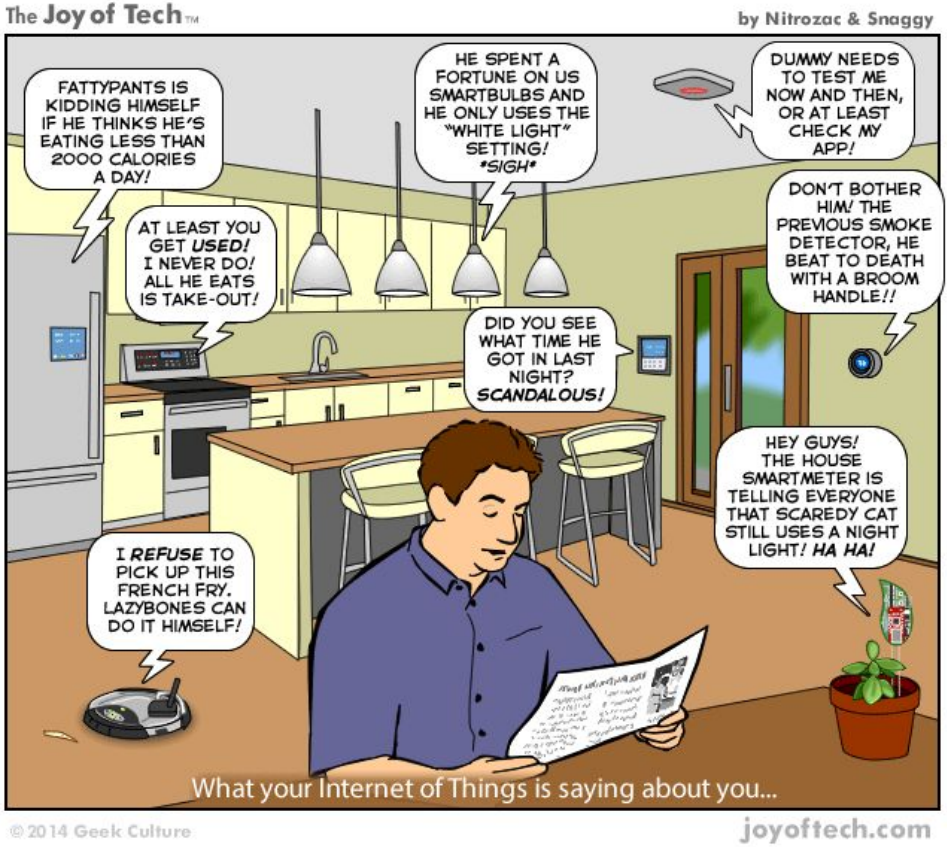








You can help us keep the comics coming by becoming a patron!
www.patreon/joyoftech



© 2014 Geek Culture
joyoftech.com

That’s all folks!

João Pedro Dias
jpmdias@fe.up.pt
https://jpdias.me

If you can't fix it,
you don't own it. *(iFixit)*